ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Code of Conduct:

I Rakshana AR(1921260027) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

ASSIGNMENTS QUESTIONS

Question: You discover a critical zero-day vulnerability in widely-used medical device software during an authorized test. The vendor is unresponsive for 90 days despite multiple attempts to contact them. Using a responsible disclosure framework, explain your next steps and justify the timeline.

1. Introduction

- A zero-day vulnerability is a security flaw for which an effective patch or widely available fix may not yet exist.
- In medical-device software, the risk may affect patient safety, device availability, clinical workflows, and medical decisions—not only data confidentiality.
- Responsible disclosure means privately notifying the appropriate parties, allowing a reasonable opportunity to investigate and fix the flaw, and reducing avoidable harm.
- Stay within the written scope; authorization does not extend to other devices or patient data.

2. Verify and document the finding safely

- Validate the finding only with the least intrusive method allowed by the authorization.
- Do not risk interrupting a device, changing clinical data, affecting patient care, or creating an unsafe condition. Stop and escalate if further testing could cause harm.
- Record the product and software version, trigger conditions, security impact, test date, relevant logs/screenshots, and a concise reproduction description.
- Minimize and sanitize evidence to exclude unnecessary patient-identifiable information, credentials, and sensitive operational details.
- Keep a confidential audit trail of actions, evidence, messages, and timestamps.

3. Make and document coordinated disclosure attempts

- Report promptly through the vendor's Product Security Incident Response Team (PSIRT), vulnerability portal, or published security contact.
- Include affected versions, impact, sufficient evidence to reproduce the issue, and confirmation that it was found during an authorized assessment.
- Request acknowledgement and a remediation plan; use other legitimate security or healthcare-sector contacts if appropriate.
- Keep copies of reports, delivery confirmations, follow-ups, and contact attempts. Explain the potential patient-safety risk clearly and professionally.
- The goal is remediation and risk reduction—not threats or premature publication.

4. What to do after 90 days without a response

- Do not automatically publish full exploit details. Escalate to an independent coordinator or relevant national cybersecurity or medical-device authority.
- Depending on the jurisdiction, options may include a national CSIRT, a medical-device regulator, or CISA's vulnerability-coordination channels in the United States. In India, CERT-In may be an appropriate contact; confirm the applicable regulator and reporting duties.
- Provide the coordinator with the evidence package, vendor-contact timeline, potential impact, and reasons the lack of response is concerning.
- Ask for help contacting the vendor, assessing patient-safety implications, and agreeing on a coordinated disclosure plan.
- If there is credible and immediate patient risk, escalate sooner; do not wait for day 90.
- Keep technical details restricted to people who need them. Do not test live devices or third-party systems without separate explicit authorization.
- Where a public advisory is appropriate, coordinate it when feasible and prioritize defensive guidance —affected versions, indicators, workarounds, and patch status—without unnecessary exploit instructions.

Responsible Disclosure Flowchart

1. Discover zero-day during an authorized test

↓

2. Validate minimally, document safely, and protect sensitive data

↓

3. Notify vendor privately; request acknowledgement and a remediation plan

↓

4. Monitor risk and follow up; escalate immediately if patient risk is urgent

↓ **If no vendor response by 90 days**

Escalate to a suitable CSIRT / regulator / coordinator	Coordinate mitigation and safe disclosure; share defensive guidance

5. Justifying the 90-day timeline

- A 90-day period is a commonly used industry benchmark: it gives the vendor time to confirm the issue, assess impact, develop and test a fix, coordinate with customers, and prepare deployment guidance.
- A defined deadline discourages indefinite inaction, while documented contact attempts demonstrate a good-faith effort to support remediation.
- Ninety days is a guideline, not an inflexible rule. Patient safety and applicable law take priority.
- For severe or readily exploitable flaws, contact appropriate coordinators or authorities earlier and seek urgent mitigations. Public release may also need careful coordination if it could create immediate danger.
- The decision should balance severity, exploitability, available mitigations, vendor response, and possible harm to patients.

90-Day Action Timeline

Period	Action	Reason
Day 0	Validate safely, preserve sanitized evidence, and notify the vendor.	Create a reliable report without increasing risk.
Days 1–7	Follow up through legitimate security contacts; request acknowledgement and a remediation plan.	Confirm receipt and establish coordination.
Days 7–30	Continue documented follow-ups; escalate to a suitable security contact or coordinator if needed.	Avoid the issue being left unattended.
Days 30–60	Assess patient-safety risk with the responsible organization and seek appropriate mitigation advice.	Adjust the response to the real-world risk.
By Day 90	If still unresponsive, escalate to a CSIRT, regulator, or independent coordinator and agree on safe next steps.	Use the benchmark to prompt action, not automatic full disclosure.
Any time	Escalate immediately if there is credible, urgent risk to patients.	Patient safety overrides waiting for a deadline.

6. Ethical and legal considerations

- Act with integrity, confidentiality, proportionality, and a clear focus on reducing harm.
- Follow the engagement contract, rules of engagement, privacy/data-protection requirements, and applicable reporting obligations.
- Do not access unnecessary information, modify patient records, disrupt services, demand payment for silence, or share confidential details with unauthorized parties.
- Distinguish confirmed findings from possible consequences; do not exaggerate the impact.
- Laws and reporting duties vary by jurisdiction. Consult legal/compliance staff and relevant cybersecurity or medical-device authorities when needed. This is an ethical and operational framework, not jurisdiction-specific legal advice.

7. Conclusion

- Validate and document the vulnerability safely, notify the vendor through appropriate channels, and preserve records of contact attempts.
- If the vendor remains unresponsive after 90 days, escalate to a suitable coordinator or cybersecurity/medical-device authority and seek a coordinated disclosure plan.
- Share only the information needed to support remediation and defense. The 90-day period is a practical benchmark, but urgent risks require earlier escalation and patient safety remains the priority.

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach

Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand